

RESUMO EXECUTIVO — NIS2 PARA PMEs EM PORTUGAL

Síntese completa do curso — Módulo 1 + Módulo 2 · 7 Aulas · DL 125/2025

Este documento é a referência permanente do curso NIS2 para PMEs. Guarde-o acessível ao CISO e à gestão de topo. Resume os conceitos essenciais de cada aula, os prazos legais, as obrigações e os materiais de apoio disponíveis. **A conformidade NIS2 não é um projecto — é um processo contínuo.**

MÓDULO 1 — GOVERNANÇA E CLASSIFICAÇÃO

Aula 1.1	Introdução e Âmbito da NIS2	NIS2 é lei desde 2025 (DL 125/2025). PMEs em setores críticos DEVEM cumprir. Custo do incumprimento > custo da implementação. Registo no CNCS obrigatório. ■ Materiais: Ferramenta Autoavaliação EE/EI (Excel) · Inventário Ativos Críticos (Excel) · Checklist Higiene Cibernética (PDF) · Resumo Executivo Gestão (PDF) · Guia 4 Semanas (PDF)
Aula 1.2	Âmbito e Classificação de Entidades	2 categorias: EE (supervisão proactiva, coima €10M) e EI (supervisão reactiva, coima €7M). Regra de dimensão: ≥50 col. + setor abrangido. Excepções para microempresas em setores críticos. ■ Materiais: Fluxograma Classificação 5 Passos (PDF) · Matriz Setor×Dimensão (PDF) · Calculadora Dimensão (Excel) · Guia CAEs NIS2 (Excel) · Checklist Registo CNCS (PDF)
Aula 1.3	Responsabilidades da Gestão e Governança	Art. 20.º NIS2: gestão de topo aprova, supervisiona e é responsabilizada. CISO com reporte directo ao CEO. Formação obrigatória para gestores. Responsabilidade pessoal em caso de negligência grave. ■ Materiais: Carta Nomeação CISO (Word) · Registo de Riscos (Excel) · Dashboard KPIs Governança (Excel) · Checklist Governança Gestão (PDF editável) · Ata Reunião Cibersegurança (PDF editável)
Aula 1.4	Segurança da Cadeia de Abastecimento (TPRM)	Art. 21.º §2(d) NIS2: avaliar fornecedores antes de contratar, monitorizar continuamente. 5 cláusulas obrigatórias nos contratos. MSP é o risco mais crítico. Exit strategy documentada. ■ Materiais: Inventário Fornecedores TPRM (Excel) · Exit Strategy Fornecedores (Excel) · Template Cláusulas NIS2 Contratos (Word) · Questionário Due Diligence (PDF editável) · Matriz Responsabilidade Cloud (PDF)

MÓDULO 2 — IMPLEMENTAÇÃO E OPERAÇÃO

Aula 2.1	Medidas Técnicas e Operacionais (10 Medidas NIS2)	10 medidas obrigatórias — prioridade MÁXIMA: MFA (bloqueia 99,9% ataques), backup imutável 3-2-1, patches em ≤48h (CVSS≥9), EDR em todos os endpoints, segmentação de rede. ■ Materiais: Tracker 10 Medidas NIS2 (Excel) · Calculadora RTO/RPO Backup (Excel) · PSI — Política Segurança Informação (Word) · Cartão Emergência NIS2 A5 (PDF) · Guia Implementação MFA (PDF)
Aula 2.2	Gestão e Reporte de Incidentes	Prazos de ouro: 24h (aviso CNCS) + 72h (notificação) + 1 mês (relatório final). IRP testado = resposta 50% mais rápida. Isolar, não formatar. Não pagar resgate sem consultar PJ. ■ Materiais: Log de Incidentes (Excel) · IRP — Plano Resposta Incidentes (Word) · Template Notificação CNCS (PDF editável) · Guia Comunicação de Crise (PDF) · Checklist Forense Digital (PDF editável)

Aula 2.3	Supervisão, Auditorias e Conformidade Contínua [AULA FINAL]	CNCS pode auditar a qualquer momento — EE: proactivo, EI: reactivo (mas igualmente rigoroso). Ciclo PDCA anual. Dossier organizado. CAPA para não conformidades. Conformidade = vantagem competitiva. ■ Materiais: Dossier Conformidade NIS2 (Excel) · Calendário Anual Conformidade (Excel) · CAPA Plano Acção Correctiva (Word) · Checklist Auto-Auditoria CNCS (PDF editável) · Resumo Executivo do Curso (este documento)
----------	--	--

■ OS 3 PRAZOS LEGAIS QUE NUNCA PODE ESQUECER (Art. 23.º NIS2)		
■ 24 HORAS AVISO PRÉVIO ao CNCS Mesmo sem todos os detalhes cert@cncs.gov.pt	■ 72 HORAS NOTIFICAÇÃO DETALHADA IoCs + severidade + medidas Portal cncs.gov.pt	■ 1 MÊS RELATÓRIO FINAL Causa raiz + impacto + remediação Encerramento formal

■ ■ SANÇÕES POR INCUMPRIMENTO (DL 125/2025) ■ Entidade Essencial: até €10.000.000 ou 2% do volume de negócios mundial · ■ Entidade Importante: até €7.000.000 ou 1,4% do volume de negócios mundial · ■ Gestor pessoalmente: até €1.000.000 + suspensão de funções · ■ Publicidade da sanção: lista pública de entidades sancionadas

■ CONTACTOS ESSENCIAIS NIS2 CNCS/CERT.PT: cert@cncs.gov.pt · +351 213 038 280 · cncs.gov.pt PJ Cybercrime: +351 21 864 6400 CNPD: +351 213 928 400 · cnpd.pt Desencryção gratuita: nomoreransom.org
--

■ MENSAGEM FINAL DO CURSO A conformidade NIS2 não é um fardo — é uma oportunidade de profissionalizar a gestão de riscos da sua empresa. Uma PME conforme com a NIS2 é mais resiliente, mais confiável para os seus clientes e mais competitiva no mercado. O CNCS é o seu regulador, mas a resiliência da sua empresa está nas suas mãos.
